CVEs más relevantes de la semana

Del 10/10/2026 al 17/10/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-108707

Descripción: Wukong_HRM through commit 186115e contains an authentication bypass vulnerability in ParamAspect that allows unauthenticated attackers to call every HRM API endpoint by omitting the AUTH-TOKEN header. Attackers gain HR administrator access to read payslips, salary history and employee personal data, download attachments, and modify or delete company-wide HR records.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-10-11

CVE-2026-109321

Descripción: Grav Login OAuth plugin (grav-plugin-login-oauth) before 1.4.3 provisions OAuth accounts as ordinary Grav users with a deterministic <provider>.<id> username and an unsalted MD5 hash of the provider identifier as the password, without disabling password login. Unauthenticated remote attackers who learn or guess a provider identifier can reproduce these credentials and log in, gaining administra...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-1391

Tecnología: No especificado

Publicado el: 2026-10-12

CVE-2026-109566

Descripción: Rapyd Admin from 9.0.0 before 9.20.0 contains a hard-coded credentials vulnerability that allows remote unauthenticated attackers to gain super-admin access through an AuthSeeder-created admin@laravel account with password admin. The account is seeded by the setup installer and silently re-created on every rpd:make run, letting attackers log in as a global super admin bypassing per-record autho...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-10-12

CVE-2026-19622

Descripción: IBM Planning Analytics 2.0, and 2.1 could allow a remote attacker to bypass authentication and escalate privileges due to improper validation of sub-requests.

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-10-12

CVE-2026-82101

Descripción: IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service due to a path traversal vulnerability.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:N/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-10-12

CVE-2026-82110

Descripción: IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper validation of pathname during a path traversal.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:N/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-10-12

CVE-2020-37282

Descripción: office-converter through 1.0.2 contains an OS command injection vulnerability that allows attackers to execute commands by supplying a crafted fileName to generatePdf() or generateHtml(). Attackers can embed $(...), backticks, or a closing quote with shell metacharacters in the file name, which is concatenated into an unoconv command run via child_process.exec(), executing commands with Node.js...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-14

CVE-2026-110635

Descripción: webp-converter before 3.0.0 contains an OS command injection vulnerability in src/webpconverter.js helpers that run libwebp binaries via execFile with shell enabled. Attackers controlling file names or option strings passed to cwebp, dwebp, gwebp, or webpmux functions can inject shell metacharacters to execute OS commands as the Node.js process.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-14

CVE-2026-110636

Descripción: pypdftk through 0.5 contains an OS command injection vulnerability in fill_form(), dump_data_fields(), and pdftk_cmd_util() that builds shell commands from caller-supplied paths. Attackers controlling pdf_path or out_file can inject shell metacharacters interpreted by subprocess.Popen with shell=True to execute OS commands as the Python process.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-14

CVE-2026-110640

Descripción: Whisper-node through 1.1.1 contains an OS command injection vulnerability that allows attackers to execute commands by supplying crafted filePath or whisperOptions.language values to whisper(). Attackers can inject shell metacharacters or $() substitution into the command string built by createCppCommand() and run via shelljs exec() to execute commands with Node.js process privileges.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-14

CVE-2026-110957

Descripción: A vulnerability has been found in Wavlink WL-WN530BE2-A up to M30BE2_V250604. The affected element is the function sub_12580 of the file api.cgi of the component Login Processing. The manipulation of the argument REMOTE_ADDR leads to os command injection. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. Upgrading to version 2026-09-24...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-10-15

CVE-2026-111094

Descripción: In JetBrains TeamCity before 2026.2, 2026.1.4, 2025.11.8 remote code execution via a whitelist bypass in the build messages protocol was possible

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-10-15

CVE-2026-102764

Descripción: The vulnerability exists within internal components of BeyondTrust's Remote Support product. The components did not adequately validate the origin of the messages it received. Under the right conditions, this could allow an attacker to perform file operations on the appliance.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-10-15

CVE-2026-111281

Descripción: Jooan JA-A12 IP cameras with firmware 009_20171107 and 05.02.31.105 contain a remote code execution vulnerability that allows unauthenticated attackers to run root commands via hard-coded credentials. Attackers send singleCMD=SetDiagMode to /goform/SingleHandlebyCommand with an attacker-chosen authserverip and authcode, making the jooandiag daemon execute their commands through /bin/sh, giving ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-10-15

CVE-2026-111643

Descripción: Misaka Danmu Server through 2.8.9 contains an authentication bypass vulnerability that allows unauthenticated attackers to write arbitrary configuration keys via the unprotected POST /api/ui/config-history/rollback endpoint. Attackers can set the ipWhitelist key to their own /32 address, or alter trustedProxies and webhookApiKey, to access every protected endpoint as the administrator.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-10-16

CVE-2026-111690

Descripción: Simple Admin Core through 1.8.7 contains an authentication bypass vulnerability that allows unauthenticated attackers to forge super administrator tokens by using the hard-coded Auth.AccessSecret in api/etc/core.yaml. Attackers can sign a JWT with the public secret and roleId claim 001 to gain full administrative control over users, roles, menus, API authorities, configuration and tokens.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-321

Tecnología: No especificado

Publicado el: 2026-10-16

CVE-2026-111693

Descripción: DataBuff ai-apm-web through 0.1.10 contains a hard-coded default credentials vulnerability that allows unauthenticated attackers to gain administrator access using the built-in admin/Databuff@123 account. Attackers can POST these credentials to /webapi/api/v1/auth/login to obtain an administrator token and access all protected /webapi routes.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1392

Tecnología: No especificado

Publicado el: 2026-10-16

CVE-2026-111704

Descripción: LangChat through commit 2a6285a contains a missing authentication vulnerability that allows unauthenticated remote attackers to access REST controllers because no Sa-Token interceptor is registered. Attackers can query /api/v1/auth/users to read plaintext passwords, retrieve LLM provider API keys, create super-admin accounts, and modify or delete data.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-10-16

CVE-2026-110653

Descripción: The Appointment Booking Plugin – LatePoint | Calendar & Scheduling for WordPress plugin for WordPress is vulnerable to Authentication Bypass via Race Condition in all versions up to, and including, 5.7.4. This is due to a non-atomic read-modify-write on the OTP verification attempts counter in the `verifyOTP` function: the counter is incremented using a stale in-memory value with no conditional...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-10-17

CVE-2026-104736

Descripción: The LearnPress plugin for WordPress is vulnerable to PHP Object Injection in versions up to, and including, 4.4.10 via deserialization of untrusted input from the 'checkout-email' request parameter during the checkout AJAX action. The value is passed through sanitize_text_field(), which does not strip serialized object syntax, then stored in the LearnPress session table and later fed to LP_Help...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-10-17

Resumen del Reporte

CVEs analizados: 20

Promedio CVSS: 9.59

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat

